

Compliance Requirements & Review Rubric

Internal Legal & Compliance Standard

Northstar Cloud Systems, Inc. | Effective Date: January 1, 2026 | Version 2.3

This internal compliance standard defines the minimum requirements that Northstar Cloud Systems, Inc. ("Northstar") expects its customer-facing Non-Disclosure Agreements (NDAs), Terms of Service (ToS), and Privacy Policies to satisfy. It is maintained by the Legal & Compliance Department and reviewed annually. The standard functions as an operational review rubric: a document may contain additional lawful provisions beyond what is listed here, but it must not contradict these minimum requirements. Any material deviation from this standard requires written sign-off from the Chief Compliance Officer prior to execution or publication.

1. Purpose, Scope, and Applicability

This standard applies to every customer-facing NDA, Terms of Service, and Privacy Policy published or executed by Northstar, including template agreements used with prospective vendors, resellers, and enterprise customers. It does not apply to internal HR agreements, employment contracts, or one-off litigation settlement agreements, which are governed by separate standards maintained by the Employment Law and Litigation groups respectively.

Business units that commission new customer-facing legal documents, or that materially revise existing ones, must route the draft through a compliance review against this rubric before publication. Reviews are logged in the Compliance Tracker with a reviewer name, review date, and outcome classification as defined in Section 5.

2. NDA Requirements

2.1 Confidential Information

The NDA must define Confidential Information broadly enough to cover, at minimum: business plans and product roadmaps; source code and technical architecture; security information, including vulnerability and incident data; customer information; pricing and commercial terms; non-public financial information; and any other information marked, or reasonably understood under the circumstances, to be confidential.

2.2 Permitted Use and Need-to-Know Disclosure

Confidential Information may be used only for the stated business purpose and may not be used for competitive purposes. Disclosure to employees, contractors, professional advisers, or affiliates is permitted only when they have a legitimate need to know and are bound by confidentiality obligations at least as protective as those in the NDA itself.

2.3 Exclusions

Information is not Confidential Information if it was already lawfully known without restriction, becomes public without breach of the agreement, is independently developed without reference to the Confidential Information, or is lawfully received from a third party without a duty of confidentiality.

2.4 Security and Incident Notification — Minimum Standard

The recipient must use reasonable administrative, technical, and physical safeguards to protect Confidential Information against unauthorized access, use, alteration, or disclosure. **Any actual or reasonably suspected unauthorized access to, or disclosure of, Confidential Information must be reported in writing to Northstar's Legal & Compliance Department within twenty-four (24) hours of discovery.** Notice under this section must be sent regardless of whether the incident also triggers notification obligations under applicable

data breach law.

2.5 Duration of Confidentiality Obligations — Minimum Standard

Confidentiality obligations must survive termination of the relevant agreement for a period of no less than three (3) years. Trade secrets must remain protected for as long as they continue to qualify as trade secrets under applicable law, without a fixed expiration.

2.6 Return or Deletion, and Remedies

Upon written request or termination of the relevant relationship, the recipient must return or securely delete Confidential Information, subject to legally required retention and routine backup exceptions. The NDA must state that monetary damages may be an insufficient remedy for breach and must not foreclose a party's ability to seek injunctive or other equitable relief.

2.7 No License

Disclosure of Confidential Information does not grant intellectual property ownership or a license, except the limited right necessary to use the Confidential Information for the stated purpose.

3. Terms of Service Requirements

3.1 Service Description and Acceptable Use

The ToS must clearly describe the service, account holder responsibilities, and acceptable use rules, and must expressly prohibit unlawful use, unauthorized access to systems or accounts, distribution of malware, abuse of the service, infringement of third-party intellectual property or privacy rights, and attempts to circumvent security controls.

3.2 Customer Content

Customers must retain ownership of content they submit to the service. The company may process that content only to provide, secure, maintain, and improve the service, and only to the extent permitted by the ToS and the Privacy Policy read together.

3.3 Security, Availability, and Liability

The ToS should describe security practices at a high level and must not promise uninterrupted or error-free availability unless a separate Service Level Agreement expressly provides otherwise. Limitations of liability and warranty disclaimers must be clearly stated and must not purport to exclude liability that applicable law does not permit to be excluded.

3.4 Privacy Alignment — Minimum Standard

The ToS must expressly state that personal information is handled in accordance with the Privacy Policy, and must not independently grant data-use, data-sharing, or data-retention rights that conflict with the Privacy Policy. Where the ToS discusses data handling, it should reference the Privacy Policy rather than restate retention or sharing terms in a way that could drift out of sync over time.

3.5 Fees, Termination, and Changes

Where paid services exist, billing, cancellation, suspension, and termination rules must be stated clearly. Material changes to the ToS should be communicated through reasonable advance notice where practicable, and the document should describe how continued use after an effective date may constitute acceptance where legally permitted.

4. Privacy Policy Requirements

4.1 Categories of Data and Purposes

The Privacy Policy must identify categories of personal information collected — such as account information, contact details, usage data, device information, and information voluntarily submitted to the service — and must explain the purposes for collection, including service delivery, security, support, analytics or improvement where applicable, and legal compliance.

4.2 Sharing and Retention — Minimum Standard

The policy must identify relevant categories of recipients, such as service providers, professional advisers, affiliates, or authorities when legally required. **It must describe retention criteria or specific retention periods for each major category of personal information it discusses — a generic statement that data is kept “as long as necessary”, without any category-level detail, does not satisfy this requirement.**

4.3 Security, Rights, and Cookies

The policy must describe reasonable security measures without promising absolute security, should explain applicable privacy rights and how individuals can submit requests, and, if cookies or similar technologies are used, must describe their purpose and point users to available controls.

4.4 International Transfers and Contact

If data is transferred internationally, the policy must explain that such transfers may occur and describe applicable safeguards at an appropriate level of detail — a bare assertion that transfers are “protected” without naming a mechanism (such as Standard Contractual Clauses or an adequacy decision) is insufficient. A privacy contact method must be provided.

5. Cross-Document Consistency Rules

Because the NDA, ToS, and Privacy Policy are reviewed and updated on independent schedules by different drafting owners, they are the most common source of unintentional contradictions. The following rules govern how the three documents must relate to one another:

- **Data use consistency** — the ToS must not authorize collection, use, disclosure, sale, or retention of personal information in a way that contradicts the Privacy Policy.
- **Confidentiality consistency** — the NDA must not claim ownership of Confidential Information that conflicts with the ToS or Privacy Policy, and the ToS must not waive NDA confidentiality protections.
- **Retention consistency** — if the Privacy Policy states a retention period or deletion approach for a category of data, no other document may promise a materially incompatible retention rule for that same category.
- **Customer content consistency** — the ToS must preserve customer ownership of submitted content while granting only the operational rights needed to provide the service.
- **Legal priority** — where documents conflict, the company should state an explicit order of precedence or otherwise ensure the documents are drafted consistently.

6. Review Outcome Rubric

Outcome	Definition
COMPLIANT	No material contradiction with this standard is identified and the required provisions are substantially p
PARTIALLY_COMPLIANT	The documents generally follow the standard but contain one or more material omissions, ambiguities,

NON_COMPLIANT	A material provision contradicts the standard or another company document, creating a significant com
INSUFFICIENT_EVIDENCE	The provided documents do not contain enough information to make a reliable determination.

7. Review Metadata

Owner: Legal & Compliance Department. Applies to: customer-facing NDA, Terms of Service, and Privacy Policy templates and executed instances. Version: 2.3. Effective date: January 1, 2026. Next scheduled review: January 1, 2027. Questions regarding this standard may be directed to compliance@northstarcloud.example.

8. Escalation and Enforcement

A document reviewed under this standard and classified NON_COMPLIANT may not be published or executed until the identified issue is remediated and re-reviewed, unless the Chief Compliance Officer grants a time-limited exception in writing, with a documented remediation plan and deadline. A PARTIALLY_COMPLIANT classification requires the reviewer to log the specific omission or ambiguity and assign a remediation owner and target date in the Compliance Tracker; publication may proceed at the business owner's discretion pending remediation, unless the reviewer determines the gap presents elevated risk, in which case the NON_COMPLIANT escalation path applies instead.

Repeated PARTIALLY_COMPLIANT or NON_COMPLIANT findings against the same document family within a twelve month period trigger a mandatory root-cause review by the Legal & Compliance Department, which may recommend process changes to the relevant drafting team.

9. Training and Awareness

Personnel who draft, review, or approve customer-facing NDAs, Terms of Service, or Privacy Policies must complete compliance training on this standard upon assignment to such responsibilities and on each annual update to this standard. The Legal & Compliance Department maintains a record of completed training and may restrict document-review permissions for personnel who have not completed current training.

10. Recordkeeping

Each compliance review conducted under this standard must be logged in the Compliance Tracker with, at minimum: the document reviewed and its version; the reviewer's name; the review date; the outcome classification under Section 6; and, for PARTIALLY_COMPLIANT or NON_COMPLIANT outcomes, a description of the issue and the remediation owner and target date. Records must be retained for at least seven (7) years to support audit and regulatory inquiries.

11. Definitions

“Material”

For purposes of this standard, a deviation from a requirement is “material” if it would be reasonably likely to affect a customer's or regulator's assessment of Northstar's data-handling or confidentiality commitments, or if it creates a meaningful risk of contractual or legal exposure.

“Drafting Owner”

The business or legal team responsible for maintaining a given customer-facing document and routing it through compliance review prior to publication or execution.

Appendix A: Quick-Reference Review Checklist

Reviewers may use the following checklist as a starting point; it does not replace a full reading of Sections 2 through 5 above.

Document	Checkpoint
NDA	Confidential Information definition covers all seven listed categories (§2.1)
NDA	Breach/unauthorized-access notice required within 24 hours (§2.4)
NDA	Confidentiality survives termination for at least 3 years (§2.5)
ToS	Expressly states data is handled per the Privacy Policy (§3.4)
ToS	Customer retains ownership of submitted content (§3.2)
Privacy Policy	States a specific retention period or criterion per data category (§4.2)
Privacy Policy	Names an international-transfer safeguard mechanism, if applicable (§4.4)
All three	No document grants rights that conflict with another (§5)